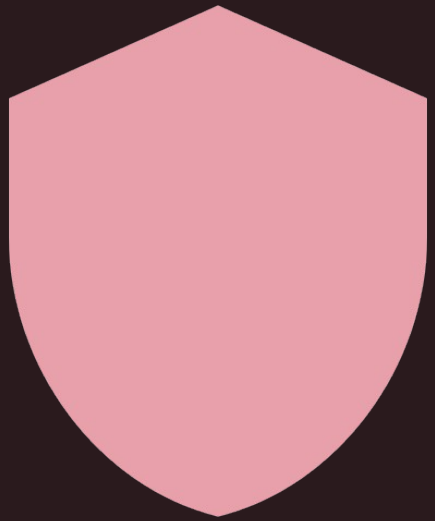
Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

PRINCIPLES OF INFORMATION SECURITY

What we protect, and from what

Day 1 - Morning

Running case: Taxila College, a fictional college



Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

Today

What Taxila must protect, and the words for what could go wrong.

- Data, information and knowledge - 30 min
- Confidentiality, integrity and availability - 30 min
- Authenticity and accountability - 30 min
- Asset, threat, vulnerability and risk - 30 min
- Controls, the law and personal data - 30 min



Today serves two outcomes

LO1 Explain the fundamentals of information security.

LO2 Discuss the key characteristics of cryptography and cryptographic systems.

LO3 Analyze the principles of encryption, decryption, hashing, and data integrity.

LO4 Outline the process of ensuring digital security.

LO5 Describe the fundamentals of threats and countermeasures.

LO6 Explain the fundamentals and process of business continuity planning.

Last semester at Taxila College

1. A **leaked paper**: a draft exam paper appeared on a student messaging group
2. A **changed grade**: a final grade was raised, and nothing showed who did it
3. A **dead deadline night**: the fee payment page stopped for three hours
4. A **message from the Registrar** that was not from the Registrar

By lunchtime you can name exactly what went wrong in each.

CONCEPT 1

Data, information and knowledge

Taxila keeps grades, mail and exam papers, each at a different sensitivity.

TRY IT FIRST

A raw value gains context and becomes information.

30 min

A value means nothing until context is added

- A raw value such as `78` has no meaning on its own
- Add context, such as a student's final grade, and it becomes **information**
- Put information together and apply it, and it becomes **knowledge**

YOU ALREADY KNOW THIS

A parcel has an address label. A worker who sees several parcels for one address knows they belong to one family.

MAPPING

the parcel = data · **the address on the label =** the context that makes it information · **knowing which parcels travel together =** knowledge

Demonstration: data, information and knowledge

1. Type a value, with no label
2. Choose a label and watch it become information
3. See it beside other information and read the knowledge
4. Change the label and watch the class change too

Three shapes of data, six stages of life

Shapes

- **Structured**: fixed rows and columns, like student records
- **Semi-structured**: labels but no fixed table, like email headers
- **Unstructured**: free text, like the body of an email

Lifecycle

- Create, store, process
- Share, archive, destroy
- Every stage can be attacked

Follow one grade from create to destroy: where is it most exposed?

Four classes, one test

- **Public**: may be published, like the course catalogue
- **Internal**: harmless if leaked, but not published, like timetables
- **Confidential**: a leak harms a person or the college, like grades
- **Restricted**: serious harm or against the law, like exam papers

The test for every class is the harm a leak would cause.

T TAXILA

Taxila keeps structured grades, unstructured mail and restricted exam papers, each at a different sensitivity.

CONCEPT 2

Confidentiality, integrity and availability

The leaked paper, the changed grade and the dead fee night.

TRY IT FIRST

A message is read, altered and then blocked, one property at a time.

30 min

Three properties, each known by its loss

C
CONFIDENTIALITY

Only authorised people can read the data.

TAXILA
The exam paper was read before the exam.

I
INTEGRITY

The data has not been changed without permission.

TAXILA
A grade was changed and kept.

A
AVAILABILITY

The data and service are there when needed.

TAXILA
The fee page did not respond.

One can be lost while the others **hold**.

Demonstration: read, change, block

1. Send a grade with nothing going wrong
2. Turn on an unknown copy point and send it again
3. Turn on a change in transit and send it again
4. Turn on an overload and send it again

Each time, ask: what arrived, and what was lost?

A post box that keeps all three

YOU ALREADY KNOW THIS

A post box has a sealed slot, a tamper strip across its door, and a front that is always open for posting.

MAPPING

the seal = confidentiality · **the tamper strip =** integrity · **the box always open to post =** availability

T TAXILA

The leaked exam paper broke confidentiality, the changed grade broke integrity, the dead fee night broke availability.

CONCEPT 3

Authenticity and accountability

The message from "the Registrar" and the grade with no record.

TRY IT FIRST

An impersonator and a denied action show why two more properties are needed.

30 min

All three hold, and you are still deceived

The first three properties

Only the addressee read the message, it arrived unchanged, and it arrived on time.

Confidentiality, integrity and availability all hold.

× What they cannot answer

The message did not come from the Registrar. Two staff members followed its link.

Something else was lost.

Two more properties answer the questions the first three cannot.

Authenticity and accountability

- **Authenticity**: does this really come from who it claims?
- **Accountability**: can you prove who did what?
- **Non-repudiation**: the strong form, where a person cannot deny an action
- These five are the **properties**; a different list, the processes, comes on Day 5

YOU ALREADY KNOW THIS

A letter is signed by its writer, and a named witness notes who signed it.

MAPPING

the signature = authenticity · **the witness's note of who signed =** accountability · **being unable to deny you signed =** non-repudiation

The five properties at Taxila

C CONFIDENTIALITY	I INTEGRITY	A AVAILABILITY	Au AUTHENTICITY	Ac ACCOUNTABILITY
Only authorised people read it.	Not changed without permission.	There when it is needed.	It comes from who it claims.	You can prove who did what.
TAXILA *The leaked paper.*	TAXILA *The changed grade.*	TAXILA *The dead fee night.*	TAXILA *The false Registrar message.*	TAXILA *No record of who changed the grade.*

The changed grade broke **two**: integrity and accountability.

Demonstration: beyond the first three

1. Check the message against the first three properties
2. Read the mail log and see where it really came from
3. Read the change record for the grade nobody admits changing
4. Replay it with a named change record

× COMMON MISTAKE

The five properties are the three processes called triple-A.

They are separate lists. The processes come on Day 5.

CONCEPT 4

Asset, threat, vulnerability and risk

Exam papers in a shared folder, with a curious student nearby.

TRY IT FIRST

Risk falls to nothing when either the threat or the vulnerability is removed.

30 min

Four words for what could go wrong

- An **asset** is anything worth protecting
- A **threat** is what could cause harm
- A **vulnerability** is the weakness that lets it
- **Risk** combines how likely the harm is and how much it would cost

YOU ALREADY KNOW THIS

A shop keeps cash in its till, a back window is unlocked, and a thief walks past every evening.

MAPPING

the cash = the asset · **the thief =** the threat · **the unlocked window =** the vulnerability · **the chance and cost of a break-in =** the risk

Risk = likelihood x impact

- Taxila scores likelihood and impact each from 1 (low) to 5 (high)
- Multiply them: a risk score runs from 1 to 25
- Example: likelihood 3, impact 5, score **15**
- Remove the threat or close the vulnerability, and the risk falls away

T TAXILA

Restricted exam papers in a shared folder, with a curious student nearby, are an asset, a vulnerability and a threat together.

Demonstration: the risk equation

1. Choose the exam papers row and read its three parts
2. Slide likelihood and impact and watch the score
3. Remove the threat; then put it back and close the weakness

Risk needs both a threat and a vulnerability.

Who the threat is

- An **insider** misuses access they already have
- An **organised criminal** works with others, for money
- An **opportunist** uses whatever is left open

× COMMON MISTAKE

A weakness on its own is a risk.

With no threat to exploit it, a vulnerability carries no risk.

CONCEPT 5

Controls, the law and personal data

Whose personal data does the college hold?

TRY IT FIRST

Controls sort by function and type and stack into layers.

30 min

Controls, sorted two ways

By what they do

- **Preventive**: stop the harm, like a locked door
- **Detective**: notice it, like a camera
- **Corrective**: repair it, like a backup

By how they work

- **Technical**: built into systems
- **Administrative**: rules and training
- **Physical**: locks, doors, cameras

Independent layers together: defence in depth.

No single control is enough

YOU ALREADY KNOW THIS

A building has a locked door, a camera over the door, and a plan to call for help if someone gets in.

MAPPING

the lock = a preventive control · **the camera =** a detective control · **the call-for-help plan =** a corrective control · **all three =** defence in depth

× COMMON MISTAKE

More tools always means more security.

Layers help only when each is an independent control.

Demonstration: control layers

1. Put each of seven controls in its box
2. Switch on a preventive and a detective layer
3. Let a staff sign-in leak and see what still works
4. Add a second lock on the same sign-in, and try again

Two controls that fail for the same reason are one layer.

Permission is the line the law draws

RECALL

Before Day 1 you learnt that every lab uses only your own machine and the provided material.

- Testing your own systems, or ones you have written permission for, is lawful
- Anything else is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007
- Access without lawful authority is enough; no damage is needed

× COMMON MISTAKE

Scanning a system is fine as long as you do no damage.

Without permission it is an offence under the Computer Crime Act, No. 24 of 2007.



DATA PROTECTION OFFICER

Whose personal data does the college hold, who can read it, and how would we know if someone read it who should not?

The Data Protection Officer, on your first morning.

Personal data carries duties

- Personal data is data about a person who can be identified from it
- Sri Lanka's Personal Data Protection Act, No. 9 of 2022, places duties on organisations that hold it
- Know what you hold, use it for a stated purpose, keep it safe and correct
- At the time of writing, a government order has fixed when the duties apply

T TAXILA

The Data Protection Officer asks whose personal data the college holds, under the Personal Data Protection Act.

Common mistakes

× COMMON MISTAKE

The five properties are the three processes called triple-A.

They are separate lists; the processes come on Day 5.

× COMMON MISTAKE

A weakness on its own is a risk.

With no threat to exploit it, a vulnerability carries no risk.

× COMMON MISTAKE

More tools always means more security.

Layers help only when each is an independent control.

Before the next day

READ	**Security in Computing, chapter 1** Sections 1.1 to 1.5, the introduction and security goals.
PRACTICE	**A district clinic's appointment system** Practice question 1: properties, risk and controls.
TASK	**Re-read the notes** Then attempt the practice question. *Before the next teaching day.*

Questions & Discussion

This afternoon: classify Taxila's data and start its risk register.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision 84bc9c3